

Evaluación 1: Ciberseguridad Ofensiva

Benjamín Santis Hermosilla

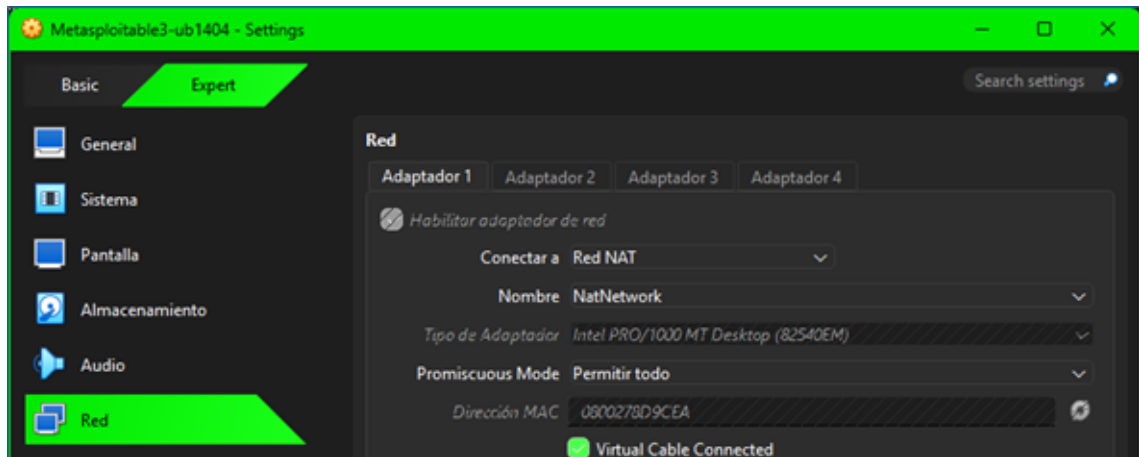
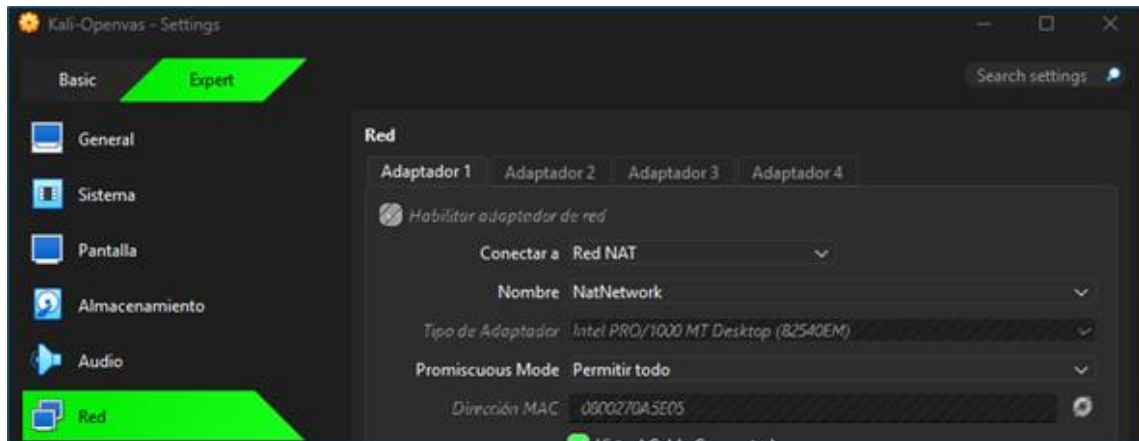
21.741.099-1

14 - 04 – 2026

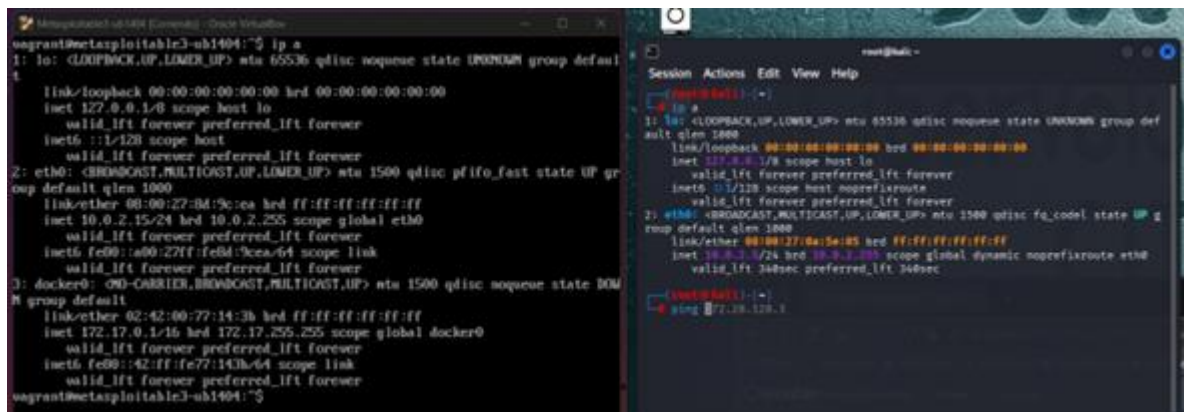
OCY1104

Desarrollo.

1. Configuración de Máquinas Virtuales.



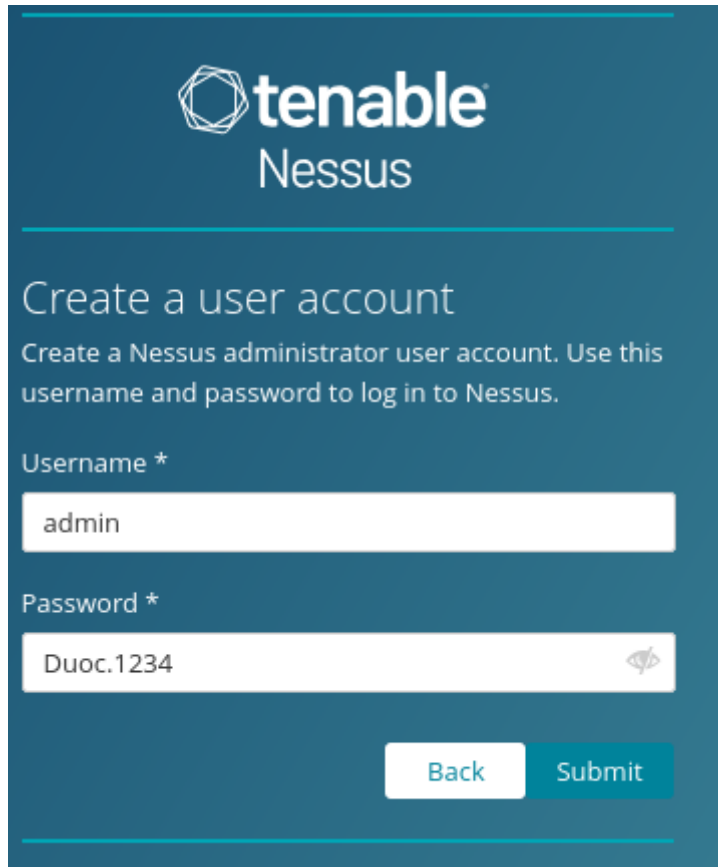
- Identificación de Maquinas:



- Kali: 10.0.2.5

- Metasploitable: 10.0.2.15

2. Configuración de Nessus



The image shows the Tenable Nessus login interface. At the top, the Tenable Nessus logo is displayed. Below it, the heading "Create a user account" is followed by the instruction: "Create a Nessus administrator user account. Use this username and password to log in to Nessus." There are two input fields: "Username *" with the value "admin" and "Password *" with the value "Duoc.1234". A toggle icon for password visibility is next to the password field. At the bottom, there are two buttons: "Back" and "Submit".

tenable
Nessus

Create a user account

Create a Nessus administrator user account. Use this username and password to log in to Nessus.

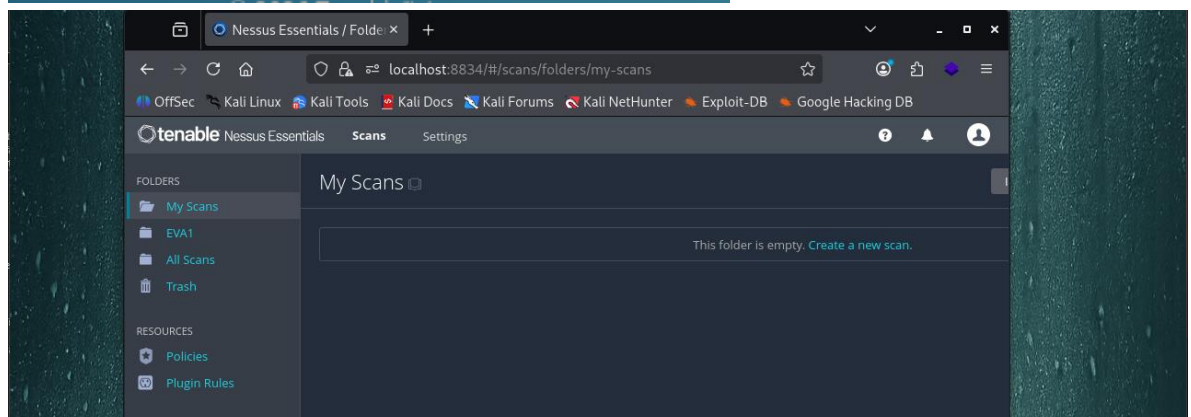
Username *

admin

Password *

Duoc.1234

Back Submit



3. Escaneo a Metasploitable

The screenshot displays the Nessus Essentials web interface. The top navigation bar includes 'Escaneos' and 'Configuración'. The main content area is titled 'Metasploitable3_EP1' and shows a summary of the scan results. On the left, there's a sidebar with 'CARPETAS' (Folders) and 'RECURSOS' (Resources). The main area features a table of hosts and a detailed view of the scan results.

Hosts Table:

Host	Auth	Vulnerabilidades
10.0.2.15	jFa...	3 2 9 4 80

Detalles de la exploración:

- Política: Escaneo avanzado
- Estado: Terminado
- Base de la gravedad: CVSS v3.0
- Escáner: Escáner local
- Inicio: Hoy a las 5:18 PM
- Final: Hoy a las 5:37 PM
- Transcurrido: 20 minutos

Vulnerabilidades:

- Crítico
- Alto
- Medio
- Bajo
- Info

Metasploitable3_EP1 / 10.0.2.15

Vulnerabilidades 44

Detalles del anfitrión:

- IP: 10.0.2.15
- MAC: 08:00:27:8D:9C:EA
- OS: Linux Kernel 3.13 en Ubuntu 14.04 (confianza)
- Inicio: Hoy a las 5:18 PM
- Final: Hoy a las 5:37 PM
- Transcurrido: 20 minutos
- KB: Descargar
- Auth: jFalla

Vulnerabilidades:

- Crítico
- Alto
- Medio
- Bajo
- Info

Sev	CVSS	VPR	EPSS	Nombre	Familia	Conde
CRÍTICO	10.0			Canonical Ubuntu Linux SEOL (14.04.x)	General	1
CRÍTICO	9.8	7.4	0.9393	Divulgación de información de ProFTPD mod_copy	FTP	1
MIKTO	...	...	...	Drupal (Múltiples Cuestiones)	Abusos de CGI	3
MIKTO	...	...	...	SSL (Múltiples Problemas)	General	7
MEDIO	6.5	4.0	0.0596	Reenvío de IP Habilitado	Firewalls	1
MIKTO	...	...	...	SSH (Múltiples Cuestiones)	Misc.	6
MIKTO	...	...	...	Servidor HTTP Apache (Múltiples Problemas)	Servidores Web	3
MIKTO	...	...	...	TLS (Múltiples Cuestiones)	Detección de servicio	3
MIKTO	...	...	...	Openbsd Openssh (Múltiples Problemas)	Misc.	2
MIKTO	...	...	...	SMB (Múltiples Cuestiones)	Misc.	2
BAJO	2.1 *	2.2	0.0037	ICMP Solicitud de marca de tiempo Divulgación de fecha remota	General	1
INFO	...	...	...	HTTP (Múltiples Problemas)	Servidores Web	9

4. Análisis de Vulnerabilidades

a. Canonical Ubuntu Linux SEoL (CVSS 10.0 — CRÍTICA)

El sistema operativo está obsoleto y ya no recibe parches de seguridad. Es un riesgo crítico y permanente porque cualquier falla nueva que se descubra quedará sin arreglar para siempre, exponiendo toda la infraestructura desde su base.

b. Divulgación de información de ProFTPD mod_copy (CVSS 9.8 — CRÍTICA)

Un error en el servicio FTP permite a cualquier persona copiar y mover archivos dentro del servidor sin necesidad de ingresar usuario ni contraseña. Un atacante remoto puede robar datos confidenciales o romper el sistema sobrescribiendo archivos clave.

c. RCE por Deserialización en el Módulo de Drupal (CVSS 10.0 — CRÍTICA)

Una falla grave en la aplicación web permite ejecutar código malicioso a distancia sin autenticación. Con una sola petición web manipulada, un atacante puede tomar el control absoluto del servidor, acceder a las bases de datos o dar de baja el servicio por completo.

5. Desarrollo Contextual:

a. ¿Qué principios de ciberseguridad ofensiva aplicaste durante este análisis?

R: Durante el análisis, primero verifique la conectividad entre las maquinas con el comando ping, así identificando la red. Luego realice un “Advanced Scan” con Nessus para detectar servicios activos y las vulnerabilidades de forma sistemática.

b. ¿Qué tácticas y técnicas podrían usar los atacantes para explotar las vulnerabilidades detectadas?

R: Un atacante podría explotar **ProFTPD mod_copy** conectándose al FTP sin autenticación para copiar archivos sensibles del servidor. Con **Drupal RCE** podría enviar datos maliciosos al servidor web para ejecutar comandos remotamente e instalar una reverse shell. Finalmente, aprovechando el **sistema operativo sin soporte**, podría usar vulnerabilidades conocidas del kernel para escalar privilegios y obtener acceso total al sistema.

- c. ¿Cómo las herramientas utilizadas contribuyeron a identificar las fallas en el sistema?

R: Nessus permitió identificar las 44 vulnerabilidades de forma automática y ordenada, comparando los servicios detectados contra su base de datos de CVEs y clasificándolos por severidad usando el estándar CVSS. Esto facilitó priorizar rápidamente las vulnerabilidades más críticas, algo que manualmente habría sido inviable de realizar en el tiempo disponible.